



A Researcher Centric Approach to Vulnerability Disclosure

Patrick Garrity
Security Researcher
VulnCheck

BUILDING ADAPTIVE SYSTEMS
FOR MODERN THREATS



Experience Related to CVD

- **Operate Coordinated Vulnerability Disclosure for Researchers**
- **VulnCheck CNA - Issue CVEs**
- **Participation in Vulnerability Related Industry Groups**
- **Interact w/ Software suppliers and security researchers**
- **Track Vulnerability Trends**
- **Track Exploitation in the Wild (KEVs)**

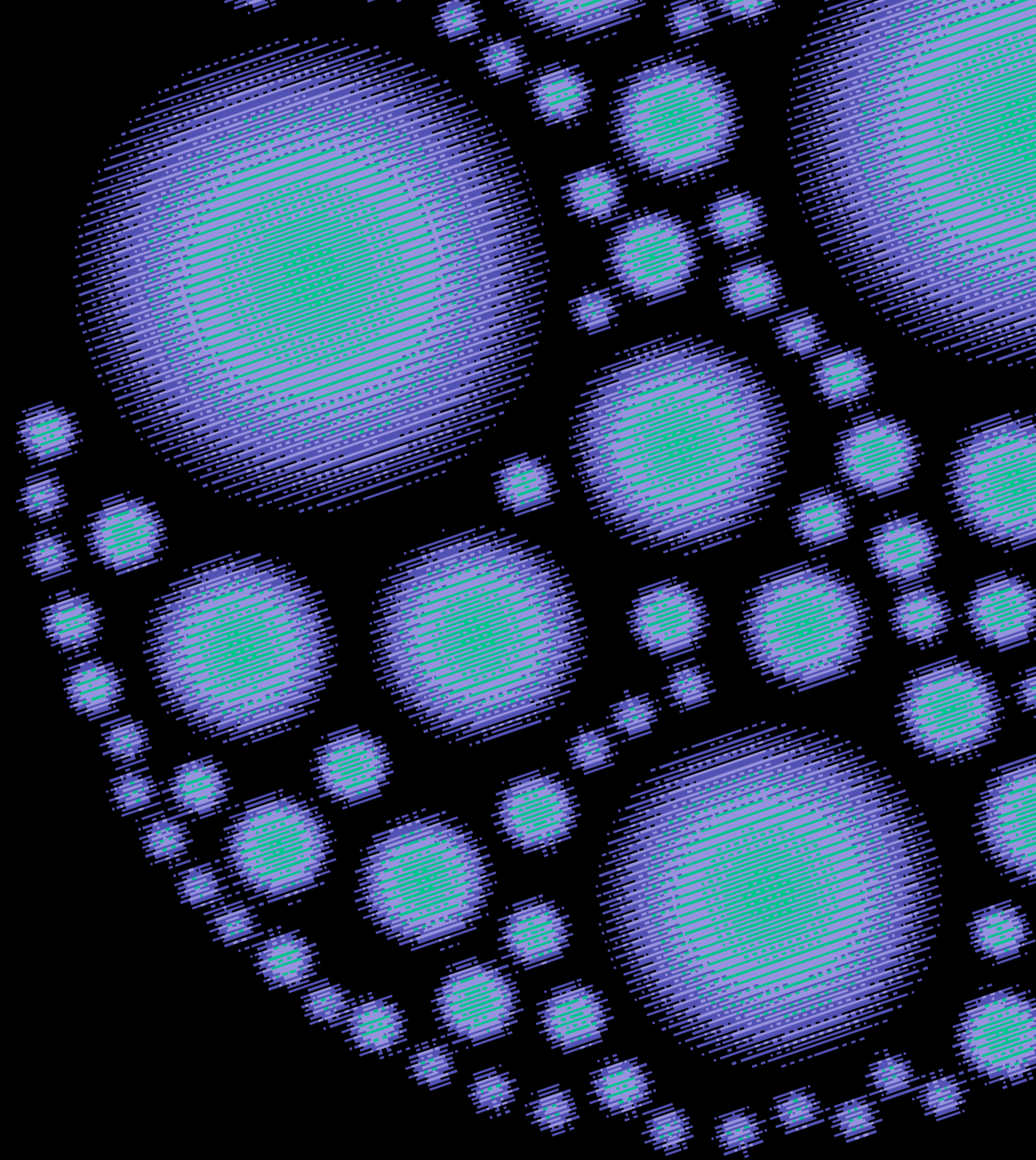
Agenda

- 1. Vulnerability Discovery**
- 2. CVD Expectations vs. Reality**
- 3. The Researcher Burden in Today's CVD**
- 4. A Researcher-Centric Approach**
- 5. Bug Bounty $\neq$ CVD**
- 6. Becoming Researcher Centric**

COORDINATED VULNERABILITY DISCLOSURE



What Happens When a Vulnerability is Externally Discovered?





WHAT A _____ MIGHT DO?

Report The Vulnerability

Not Report the Vulnerability

Publicly Publish The Vulnerability

Sell The Vulnerability

Use The Vulnerability

REPORT THE VULNERABILITY



Want a Fix



Want a CVE

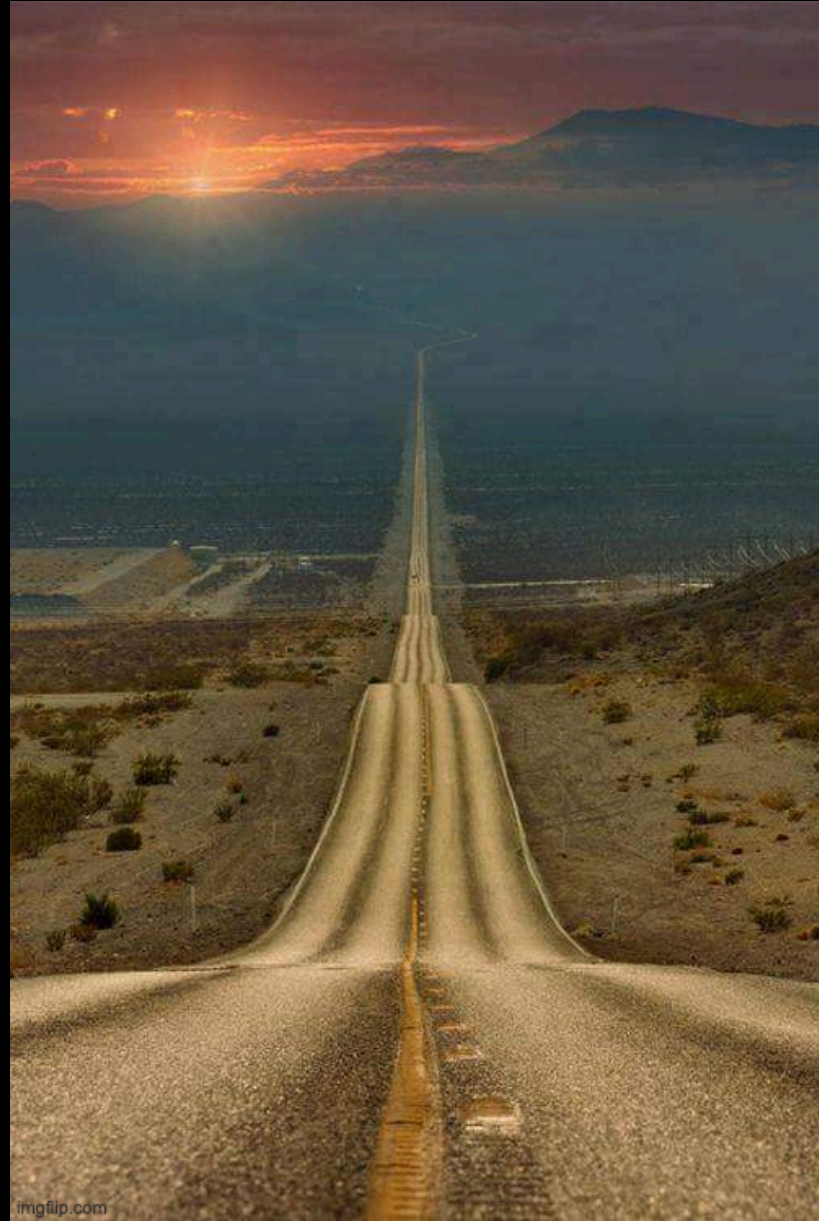


**Challenge Security
of a Product**



Bounty

NOT REPORT THE VULNERABILITY



**The Long Road
(Time Intensive)**



**Historic Lack of
Response**



**Combative
Software
Supplier**

PUBLICLY PUBLISH THE VULNERABILITY



NO RESPONSE



NOTARITY

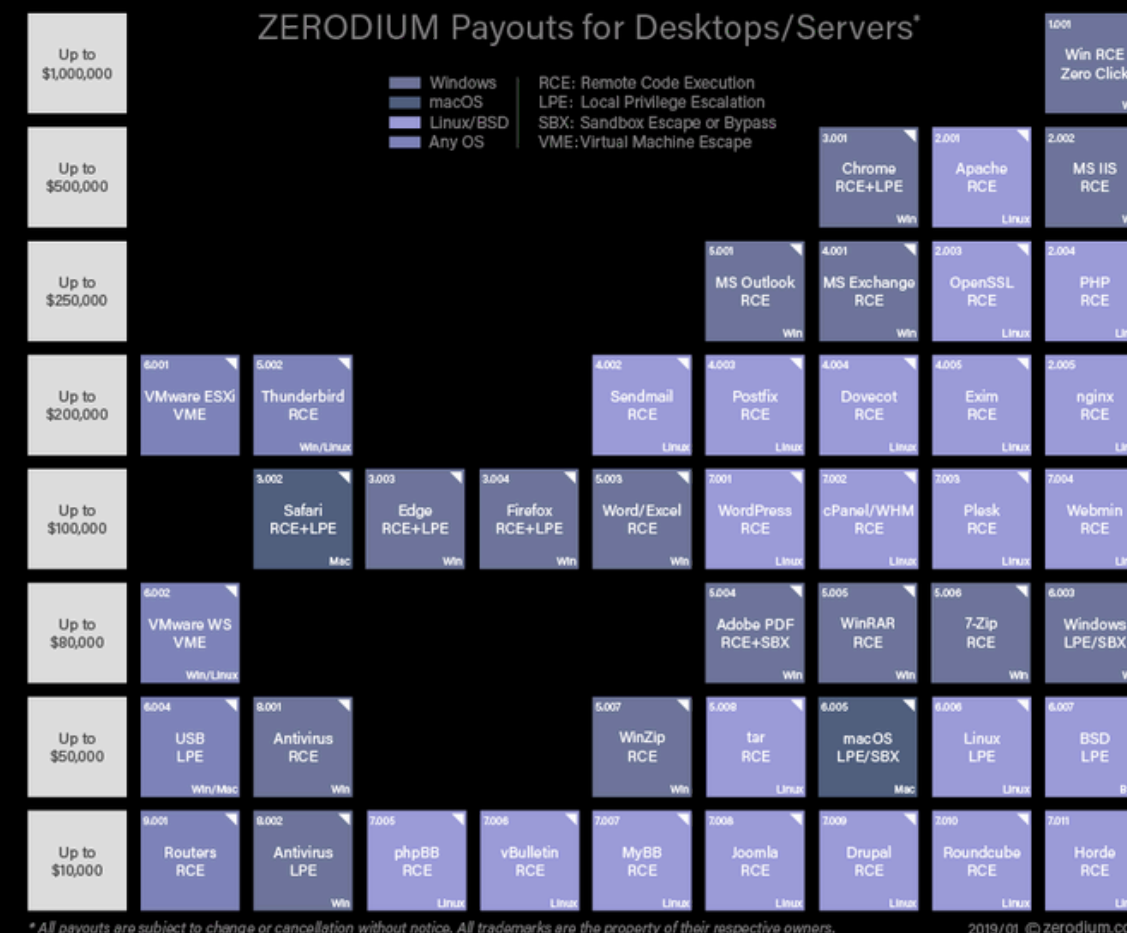


**LACK OF PUBLIC
DISCLOSURE**

SELL THE VULNERABILITY



Nation States



Zero Day Markets

“FBI HINTS IT
PAID HACKERS
\$1 MILLION TO
GET INTO SAN
BERNARDINO
IPHONE”

Governments

USE THE VULNERABILITY

Reproduction



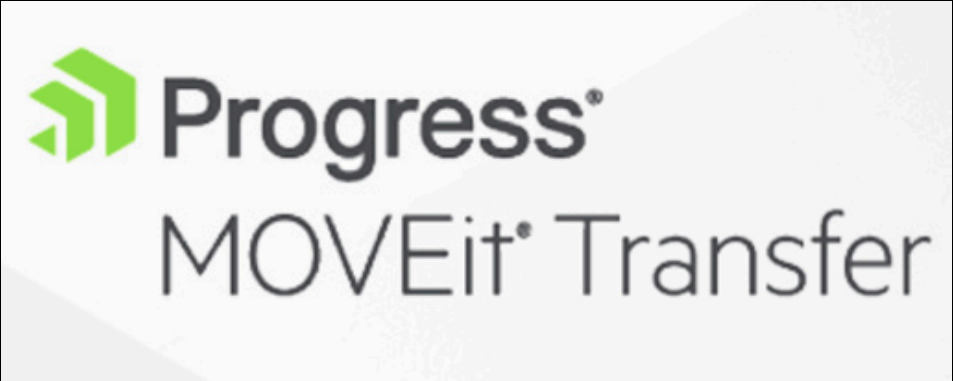
Test



Detect



ZeroDay



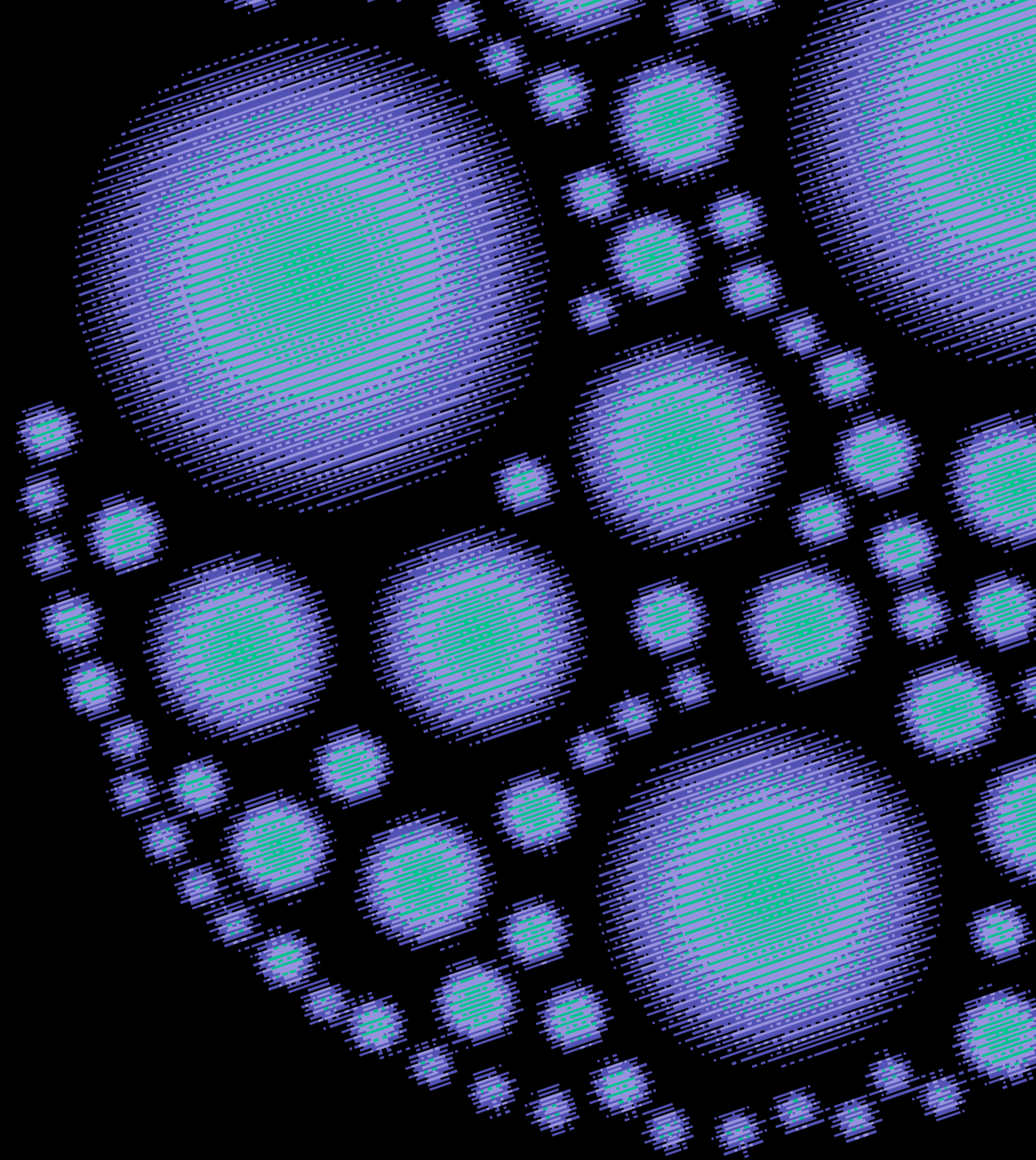
Ransomware Campaigns



Nation States



The Researcher Burden



THE RESEARCHER BURDEN

Before coordinated disclosure can begin, researchers must identify:

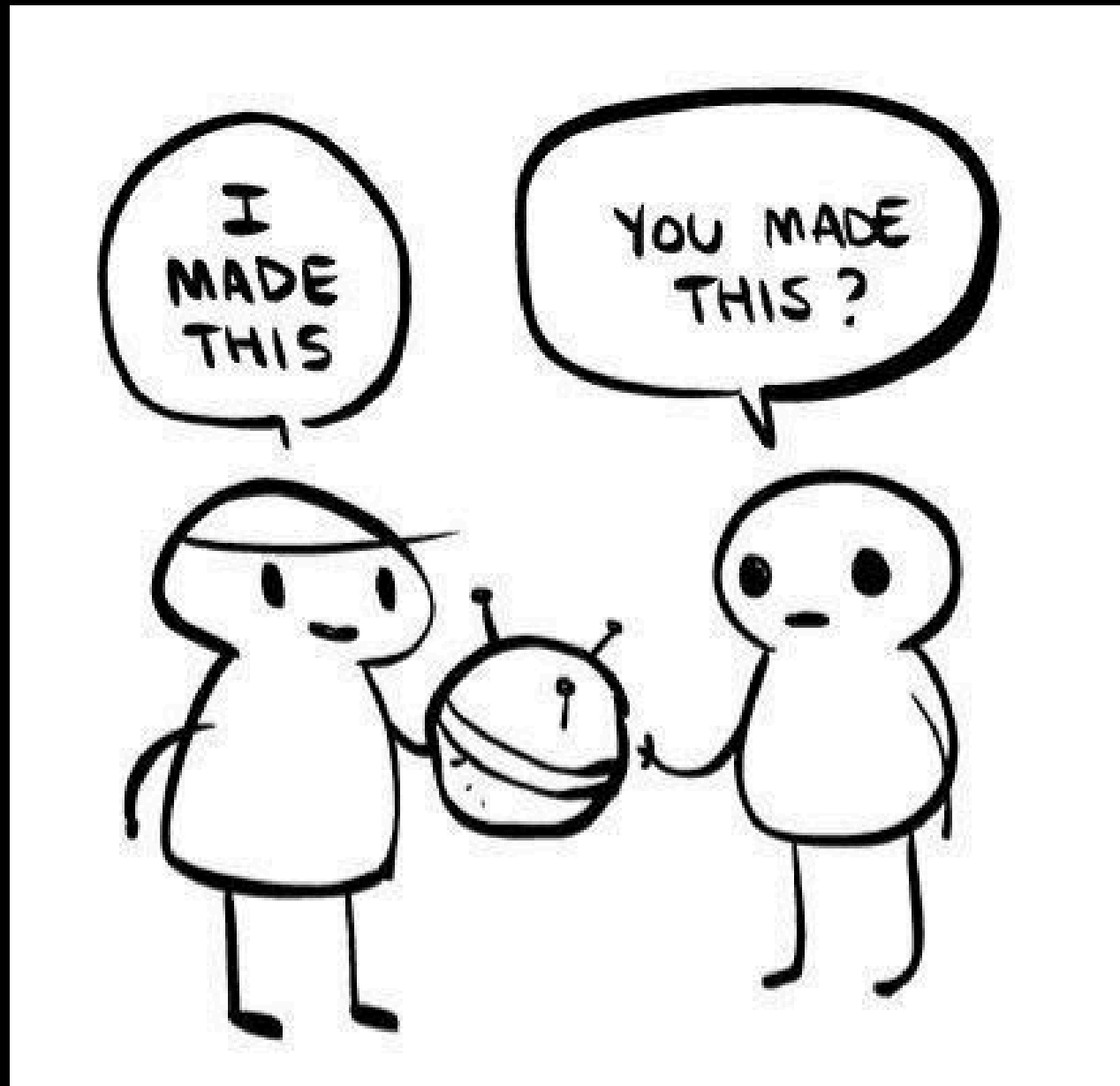
- 1. Which company owns the affected product**
- 2. Whether a PSIRT or security contact exists**
- 3. Which email or form actually works**
- 4. Whether the vendor is even the right point of contact**
- 5. Review and Consider Legal Agreements**

THE RESEARCHER BURDEN

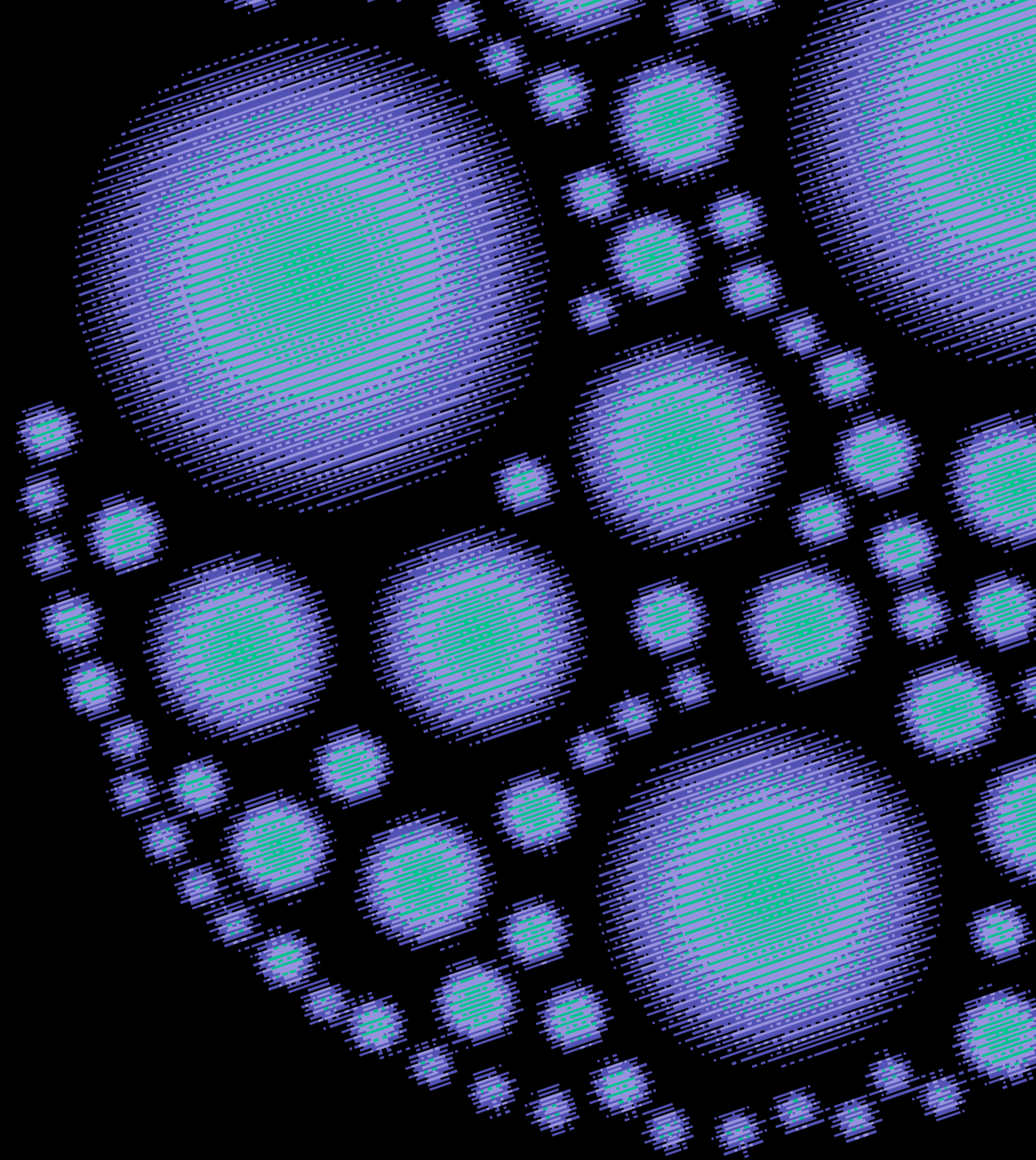
Common obstacles:

1. **security.txt is missing or outdated**
2. **CNA scope and contact info is unclear**
3. **General support queues that go nowhere**
4. **Multiple subsidiaries with no clear ownership**
5. **Lack of response**

RESEARCHER IS OFTEN FORGOTTEN



**Bug Bounty ≠
Coordinated
Vulnerability
Disclosure**



COORDINATED VULNERABILITY DISCLOSURE



VS.

BUG BOUNTY



BUG BOUNTY EXPECTATIONS

—	Critical Severity - \$2,500 - \$10,000
	CVSS Score: 9.0 - 10.0
—	High Severity - \$500 - \$5,000
	CVSS Score: 7.0 - 8.9
—	Medium Severity - \$100 - \$1,000
	CVSS Score: 4.0 - 6.9
—	Low Severity - \$100 - \$200
	CVSS Score: 0.1 - 3.9



**WHAT IS THE
SEVERITY?**

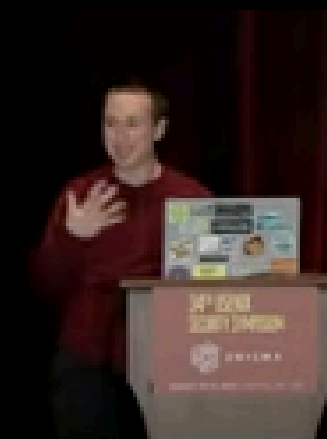
**HOW MUCH DO
I GET PAID?**

**WHEN DO I GET
PAID?**

Everything Old is New Again: Legal Restrictions on Vulnerability Disclosure on Bug Bounty Platforms

Kendra Albert
Albert Sellars LLP

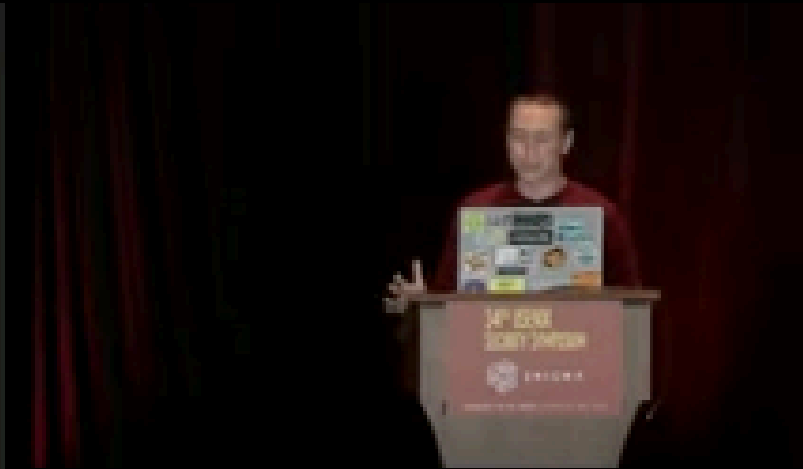
August 12, 2025
USENIX Enigma 2025



34TH USENIX
SECURITY SYMPOSIUM



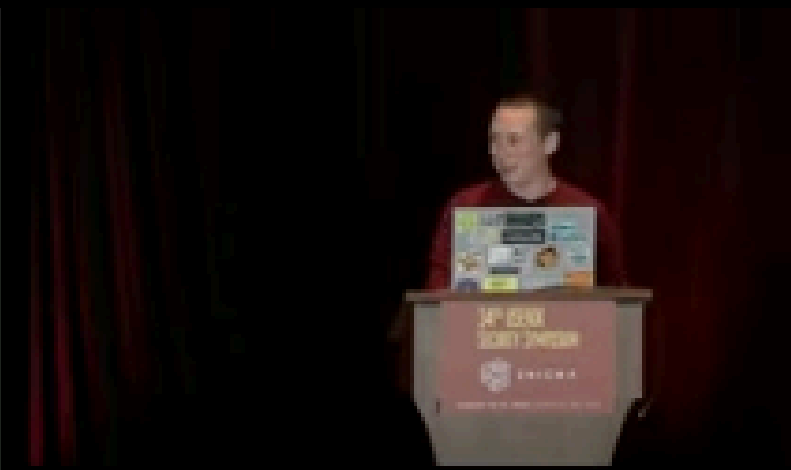
A lot of vulnerability reporting now
takes place under formal
non-disclosure agreements.



34TH USENIX
SECURITY SYMPOSIUM



...and all it took was a couple of
centralized platforms and a lot of
lawyers.



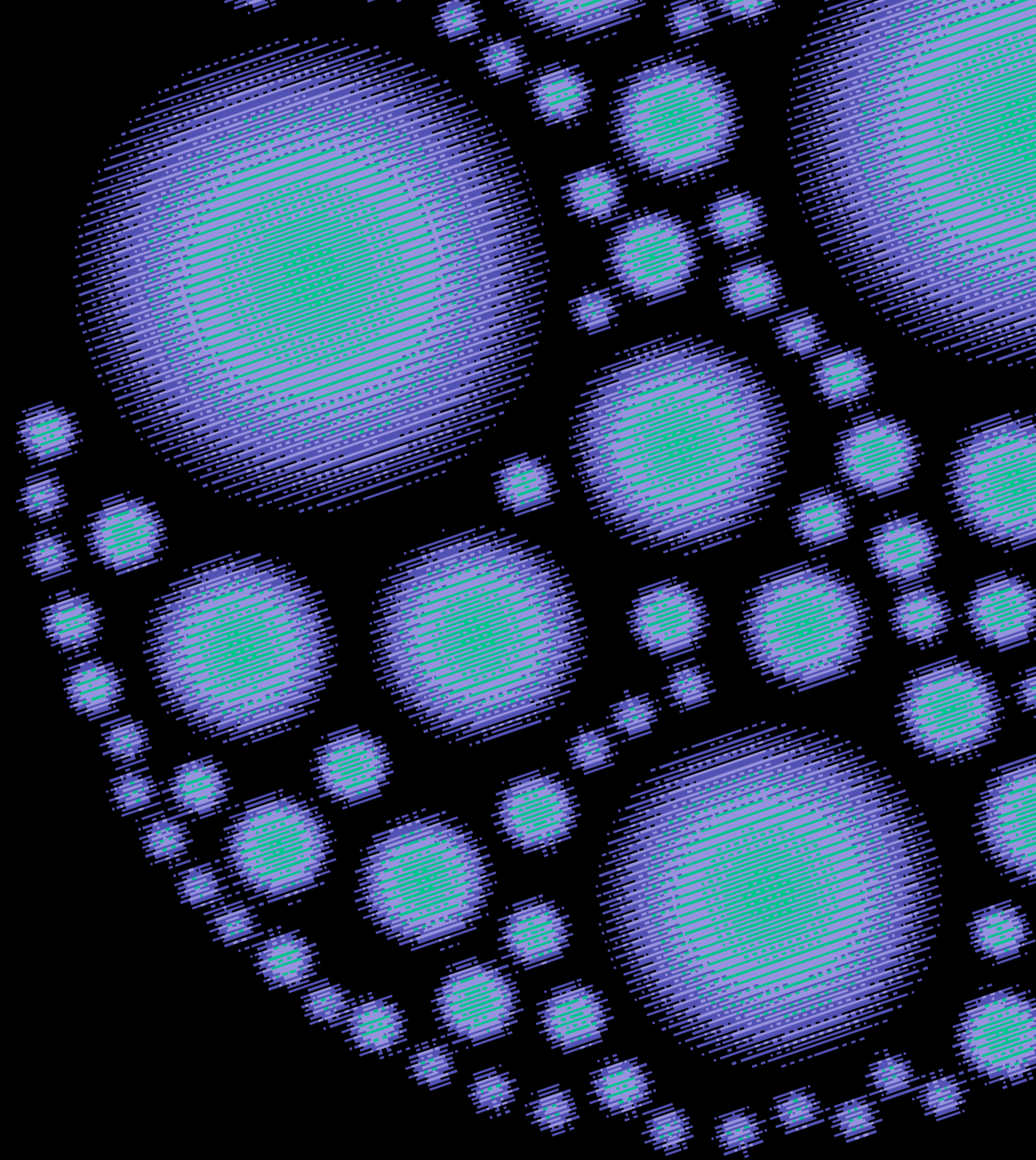
34TH USENIX
SECURITY SYMPOSIUM



BUG BOUNTY



New Challenges



AI ASSISTED VULNERABILITY DISCOVERY



- Increased Volumes
- More Detailed Reports
- More False Positives
- Researcher Collisions
- Duplicate Reports

Resurfacing Challenges w/ ~~Responsible~~ Coordinated Disclosure

SENDING MIXED SIGNALS TO RESEARCHERS

The vulnerabilities known as [RedSun](#), [UnDefend](#), [BlueHammer](#), [YellowKey](#), GreenPlasma, and MiniPlasma were not responsibly disclosed. In response to the unnecessary risk created by these disclosures, our security teams have been working around the clock to understand the impact, protect our customers, and develop security updates.

We remain firmly opposed to these actions, and any disclosure outside proper coordination that could harm our customers and the digital ecosystem. Uncoordinated disclosures that put proof-of-concept code for unpatched vulnerabilities into the hands of bad actors are never justifiable and have real-world consequences. Our security teams across the company work tirelessly tracking threat actors who look for weaknesses just like these to attack and our customers. Our Digital Crimes Unit will continue bringing cases against these actors and those that enable their criminal activity – coordinating as needed with law enforcement around the world.

FRICTION LEADS TO 0-DAY

A researcher publicly released a exploit within hours, citing past disputes with over bug handling.

The security researcher Ammar Askar found a new serious zero-day in Visual Studio Code, told a contact at GitHub about it, and published a working exploit one hour later.

“Just by clicking a link, it’s possible for an attacker to steal a GitHub token that can read and **write** to your repos, including **private ones**.” reads the [report](#) published by the researcher.

No 90-day window, no coordinated disclosure, no ticket. The researchers just dropped a PoC on the internet, because he’d been through the process before and decided once was enough.

DARKNET DIARIES

EP 114: HD

research

penetration test

bug hunter

05 April 2022 | 75:52 | Plays: 874,487

LEARN FROM HD MOORE

“ [REDACTED] did not like having vulnerabilities reported. They do anything they can to shut you up. They did not like having someone ex – releasing exploits for vulnerabilities on their platform.”

“So, they kept putting pressure on my coworkers and my boss and the CEO to get rid of me, basically, because of the work I was doing to publish vulnerabilities. That just made me angry; ”

RESEARCHER PERSPECTIVE

“Now, since this was an unknown bug to [REDACTED] and [REDACTED] was there at this hacker conference sponsoring the thing, he went up to them and told them about it.

They were like great, report it to us. I’m like no, it’s mine. Am I gonna get a reward for it? What are you gonna do with it? I found this vulnerability. It’s mine to do what I want to with it.”

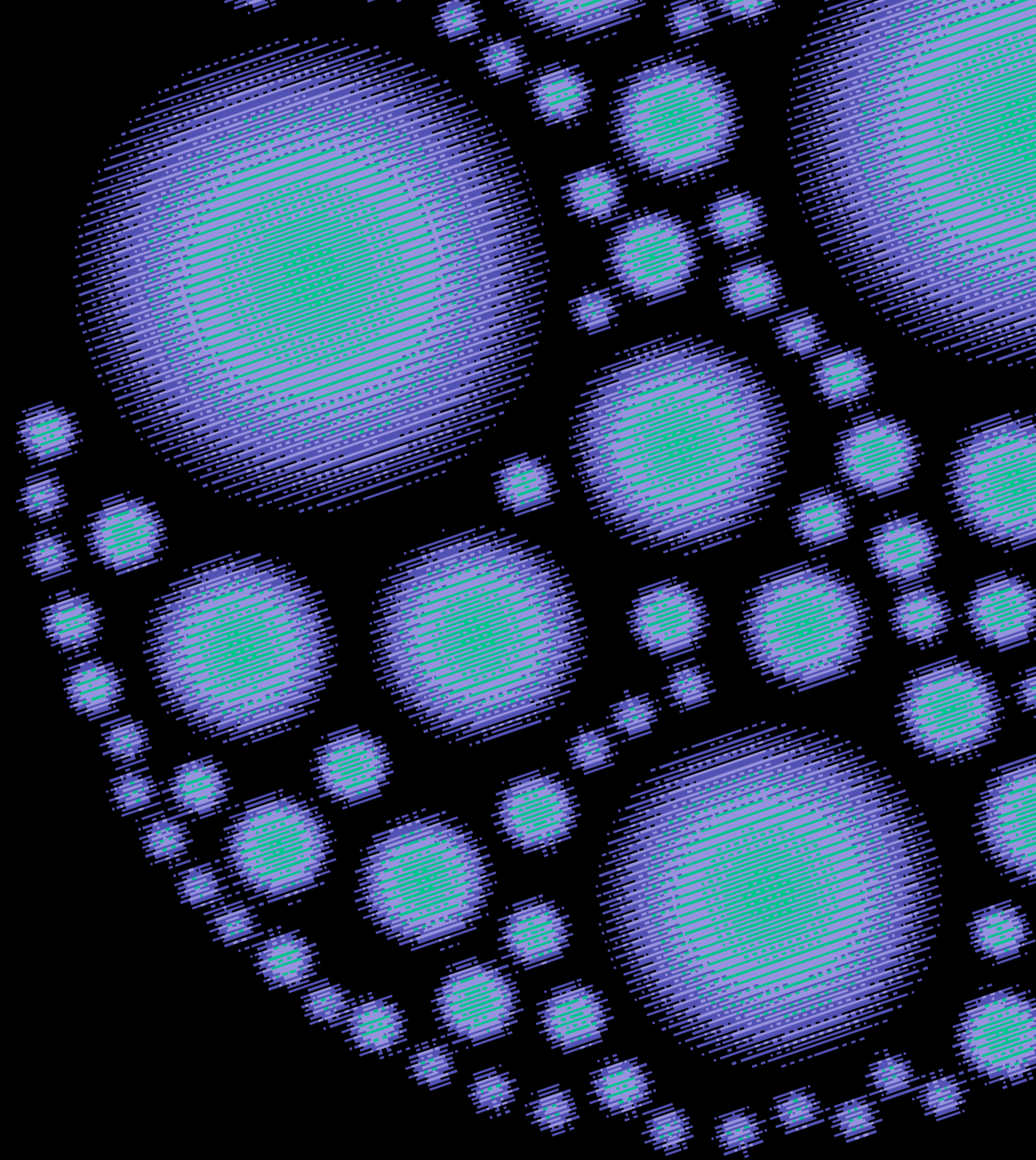
RESEARCHER PERSPECTIVE

“Now, since this was an unknown bug to [REDACTED] and [REDACTED] was there at this hacker conference sponsoring the thing, he went up to them and told them about it. They were like great, report it to us. I’m like no, it’s mine. Am I gonna get a reward for it? What are you gonna do with it? I found this vulnerability. It’s mine to do what I want to with it.”

RESEARCHER PERSPECTIVE

“So, the short version is, I’m more than happy to tell the vendors about it, but I also want to make it public at some point. These are vendors that, at the time, were sitting on vulnerabilities more than a year, two years, maybe never disclosing it. They had no motivation to ever disclose a vulnerability reported to them, and they would do anything they could to pressure you not to.”

How Do We Become More Researcher Centric?



WHAT ARE THE OBJECTIVES?

1. To ensure vendors are given a reasonable amount of time to address reported issues.
2. To provide the security community and affected users with honest, useful, and actionable vulnerability details.

Taking a Research Centric Approach to CVD

HOW TO IMPROVE THE RESEARCHER EXPERIENCE:

Clear points of contact

Multiple reporting options (Web Form / Email)

No legal obligations

No Registration

Clear expectations

Respond within 1-business day

Engage with all researchers / Not Just the First to Report

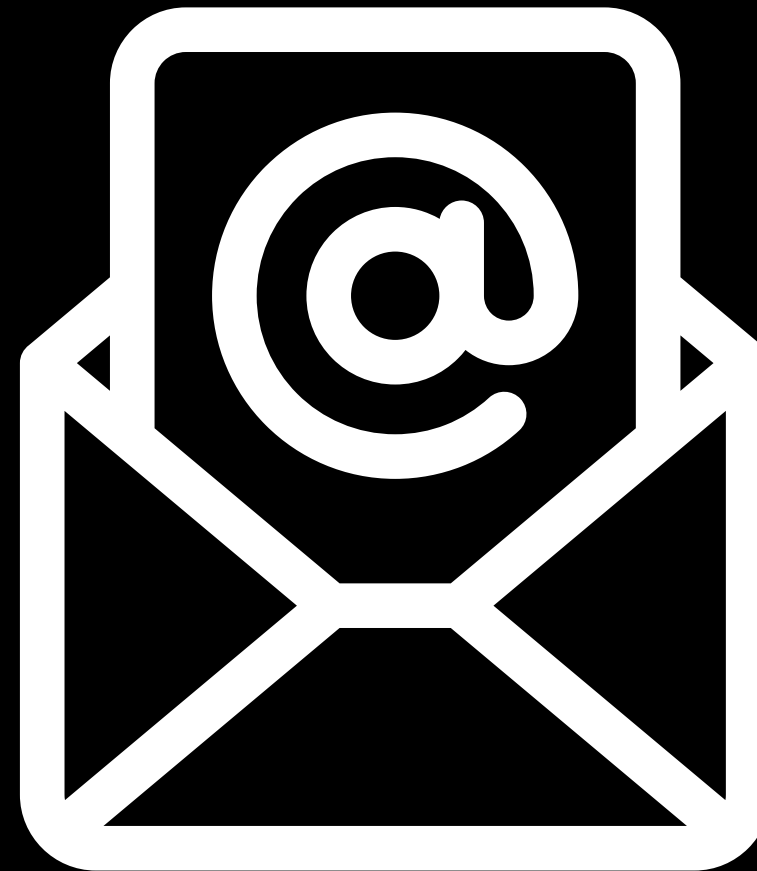
Continually update researchers

Disclose Publicly

CLEAR POINTS OF CONTACT



Security.txt



E-mail



WebForm

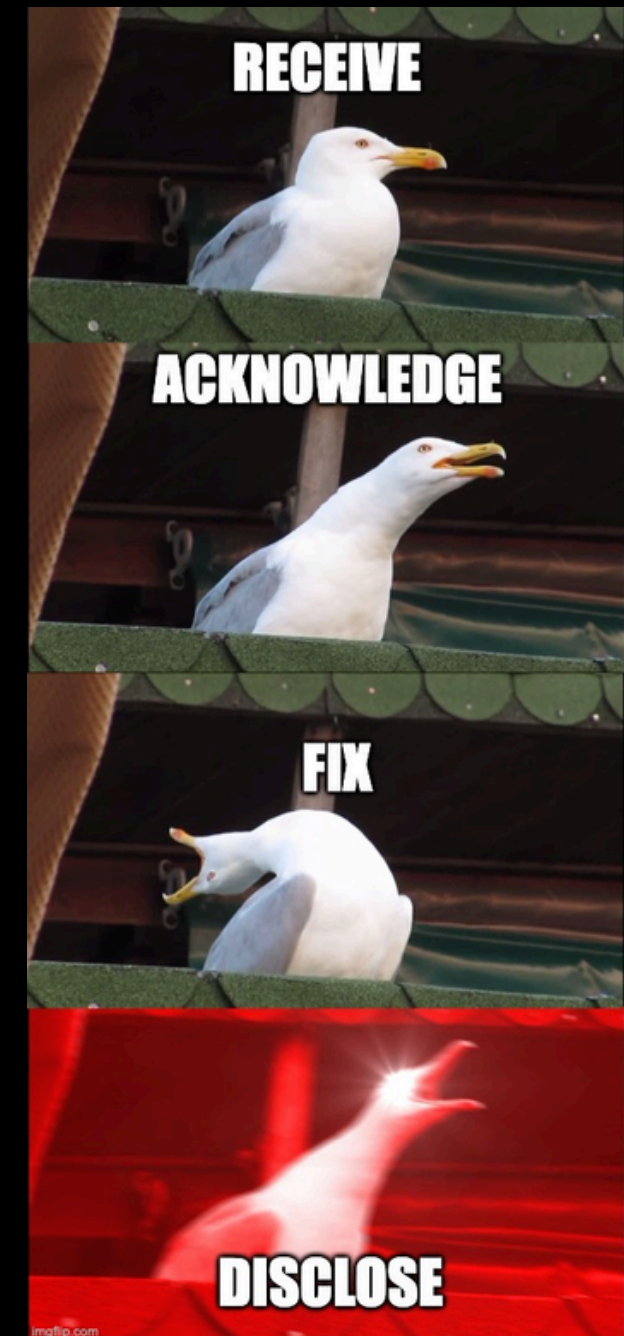
RESPONSIVE



1-Business Day



**Engage All The
Researchers**



Update Researchers

PUBLICLY DISCLOSE VULNERABILITY



RESEARCHER REPORTING EXPECTATIONS

1. Easy Way to report a vulnerability

- **Email**
- **Form**
- **No legal obligation**

2. Timely Response

- **Confirmation of report receipt**
- **Was the Vulnerability Reproducible?**

3. A Timeline For Resolution

- **When will the vulnerability be fixed?**
- **When will the patch be available?**
- **When will I be able to publish my research?**
- **When will it get a CVE?**
- **Will I be credited?**

**Right now, a researcher has found
a vulnerability in your product.
They're deciding right now whether
to tell you.**

**What have you done to deserve
that report?**

Questions?



Patrick Garrity

SECURITY RESEARCHER

Follow My Work

